# Checklist operacional de privacidade e segurança

*Guia de preparação, não certificação ou parecer jurídico. Os controles abaixo só podem ser anunciados ao cliente depois de efetivamente implementados. Ajuste as medidas ao risco e aos dados do projeto com orientação profissional quando necessário.*

## 1. Antes de oferecer tratamento de base real

- [ ] Equipamento sob seu controle, atualizado e com criptografia de disco habilitada.
- [ ] Bloqueio de tela, conta de usuário individual e senha forte.
- [ ] Autenticação em dois fatores disponível nos e-mails e serviços de troca usados.
- [ ] Pastas e permissões separadas por cliente; evitar contas compartilhadas.
- [ ] Backup protegido compreendido: localização, acesso, retenção e como ocorre a exclusão.
- [ ] Canal de transferência restrito testado; links públicos desabilitados.
- [ ] Procedimento escrito de acesso, trabalho, entrega, retenção, descarte e incidente.
- [ ] Modelo de contrato/anexo revisado por advogado e compatível com sua prática.
- [ ] Lista de ferramentas/fornecedores avaliados. Sem base real em IA pública ou conversores online sem avaliação e autorização apropriadas.
- [ ] Contato e método para receber solicitações/questões de privacidade definidos.
- [ ] Situação tributária, emissão de documento fiscal e conflito com o emprego verificados.

**Se algum item essencial não está pronto, use dados sintéticos e não receba bases reais ainda.**

## 2. A cada projeto

### Antes do envio

- [ ] Identificar finalidade e pergunta de negócio.
- [ ] Pedir só campos necessários; remover identificadores no sistema do cliente antes do envio, quando possível.
- [ ] Preferir amostra fictícia ou cabeçalhos para orçar.
- [ ] Avaliar se há dado sensível, de saúde, criança ou dado de alto risco; reduzir ou recusar sem controles adequados.
- [ ] Definir papéis reais e instruções; não presumir que o rótulo contratual resolve a análise.
- [ ] Listar destinatários autorizados e validar a base legal/autoridade de compartilhamento com o controlador.
- [ ] Acordar canal, localização, fornecedores, prazo de retenção, descarte e procedimento em incidente.
- [ ] Assinar proposta, contrato/anexo e receber o sinal antes da base real.

### Durante

- [ ] Receber somente pelo canal combinado e conferir o remetente.
- [ ] Restringir acesso e manter arquivos separados por cliente.
- [ ] Usar identificadores/códigos apenas quando suficientes; lembrar que pseudonimização não é anonimização.
- [ ] Não usar dados para marketing, treinamento, portfólio ou outros clientes.
- [ ] Não encaminhar para fornecedores, plugins, IA ou dispositivos de terceiros sem avaliação e base contratual aplicável.
- [ ] Guardar somente as cópias necessárias e proteger também exportações temporárias.
- [ ] Não usar filtro visual, ocultação de coluna ou PDF protegido por senha como substituto de autorização e minimização.

### Entrega e descarte

- [ ] Verificar conteúdo e destinatários antes do envio.
- [ ] Preferir PDF agregado quando o cliente não precisa de detalhes linha a linha.
- [ ] Para PBIX, confirmar que cada destinatário pode acessar toda a base importada; não misturar clientes.
- [ ] Entregar pela via acordada; senha por canal separado se esse controle foi acordado.
- [ ] Registrar data, versão, destinatários e confirmação de entrega.
- [ ] Executar revisões dentro do prazo contratual.
- [ ] Após o prazo definido no contrato, eliminar/devolver arquivos de trabalho e verificar lixeira, cópias e sincronizações conforme a política de backup.
- [ ] Registrar a execução e eventuais retenções legais com fundamento e prazo.

Não há aqui um prazo legal universal de 30 dias. O prazo deve ser necessário, acordado e compatível com obrigações legais e backups.

## 3. Resposta inicial a incidente

Se suspeitar de envio errado, perda, acesso indevido ou exposição:

1. Interromper o acesso ou compartilhamento comprometido, se isso puder ser feito com segurança.
2. Não apagar logs ou evidências; anotar o que ocorreu, quando, quais sistemas e arquivos podem estar envolvidos.
3. Avisar o contato designado do cliente sem demora indevida, pelo canal combinado, compartilhando fatos conhecidos e ações já tomadas.
4. Trabalhar com o cliente na contenção e preservação de evidências; não fazer alegações especulativas.
5. Solicitar apoio jurídico/técnico apropriado. As decisões de comunicação à ANPD e aos titulares dependem das obrigações, papéis e critérios legais aplicáveis; não presumir que o prestador decide sozinho.
6. Registrar linha do tempo, decisões, medidas e conclusão.

Este roteiro não substitui resposta formal a incidente ou as obrigações de notificação previstas na legislação e regulamentação aplicáveis.